

M9T9

Entrega final reestructurada del ejercicio de analisis de malware

Muestra:

7e7d0557cc95e3f509f71a72aad9b8ab85d6a681df4a46e1648e928a4be5f4be

Campo	Valor
Tipo de muestra	PE32 Windows / loader-dropper
Familia asociada por OSINT	Vawtrak / Neverquest
Arquitectura	x86 / i386
Entorno	Linux + Ghidra + x32dbg en VM Windows
Objetivo	Caracterizar la muestra, confirmar autocopia y persistencia, extraer el payload final reconstruido y recuperar configuracion/IOCs.
Version del documento	v2 - incluye IOCs, MITRE y conclusiones finales
Fecha	08/06/2026

Alcance: este documento resume el proceso tecnico seguido y reorganiza la entrega en una cadena analitica: caracterizacion, triage estatico, validacion PE, ofuscacion, dropper, analisis dinamico, payload final, configuracion, IOCs, MITRE y conclusiones.

Indice final incorporado

La estructura final prioriza la lectura cronologica y tecnica del caso: primero se estudia la muestra original, despues se confirma su comportamiento como dropper, y finalmente se analiza el payload reconstruido en memoria.

1. Informacion general de la muestra
 - 1.1 Primera caracterizacion
 - 1.2 Hashes y footprinting
 - 1.3 Consultas externas
2. Triage estatico inicial
 - 2.1 Identificacion PE y arquitectura
 - 2.2 Metadatos, imports y strings iniciales
 - 2.3 CAPA sobre la muestra original
 - 2.4 FLOSS sobre la muestra original
 - 2.5 Conclusion del triage estatico
3. Validacion de la estructura PE
 - 3.1 Secciones
 - 3.2 Data Directories
 - 3.3 Firma digital y Rich Header
4. Analisis de ofuscacion y posible empaquetado
 - 4.1 Comprobacion de UPX/packer
 - 4.2 Entropia de secciones
 - 4.3 Revision de .rdata y blobs opacos
 - 4.4 Validacion de falsos positivos MZ/PE/PK
 - 4.5 Imports sospechosos: GetProcAddress, LoadLibrary, WriteFile, VirtualAlloc
 - 4.6 Conclusion sobre empaquetado/ofuscacion
5. Analisis funcional estatico de la muestra original
6. Confirmacion del comportamiento dropper
7. Analisis dinamico
 - 7.1 Preparacion del entorno de analisis
 - 7.2 Autocopia y artefactos en disco
 - 7.3 Comprobaciones de marcadores: Xande, Mizuk y Bupra
 - 7.4 Persistencia mediante HKCU\...\Run
 - 7.5 Reserva de memoria y memoria mapeada
 - 7.6 Obtencion del payload final reconstruido en memoria
 - 7.7 Carga del payload final en Ghidra
 - 7.8 Analisis de funciones relevantes del payload final
 - 7.9 Analisis de capacidades del payload final con CAPA/FLOSS
 - 7.10 Busqueda de comunicacion C2 y WinINet
 - 7.11 Extraccion y analisis del blob de configuracion
 - 7.12 Analisis del stage/buffer dinamico adicional
 - 7.13 Tecnicas anti-analisis y cierre del proceso

7.14 Limitaciones del analisis dinamico

8. Indicadores de compromiso

9. Mapeo MITRE ATT&CK

10. Conclusiones finales

Resumen ejecutivo

La muestra M9T9 corresponde a un ejecutable PE32 de Windows asociado en fuentes OSINT a la familia Vawtrak/Neverquest. El analisis tecnico confirma un comportamiento compatible con un loader/dropper: la muestra se autocopia, crea persistencia, reconstruye un payload final en memoria y contiene configuracion de red ofuscada recuperable mediante analisis dinamico y estatico del payload reconstruido.

El hallazgo central es la separacion entre la muestra original, la autocopia persistente y el payload final reconstruido en memoria. Esta distincion evita interpretar como payload nuevo aquello que realmente es una copia del loader.

Artefacto	Clasificacion	Interpretacion
Muestra original	Loader/dropper	Binario inicial analizado. Presenta ofuscacion parcial y prepara etapas posteriores.
C:\ProgramData\Dizla\Zedyi.exe	Autocopia	Mismo hash que la muestra original; se usa para persistencia.
mapped_inner_payload_00110000_size_00016000.bin	Payload final	PE reconstruido en memoria. Entry dinamico: 0x001166F2.
payload_final_06CBD5E8_1B0000.bin	Dump de payload	Volcado mas amplio desde otra ejecucion/base de memoria.
config_blob.bin	Configuracion	Bloque con seis entradas descifradas mediante LCG + XOR.
Blob Base64 de 332 caracteres	Datos opacos	Decodifica a 249 bytes de alta entropia; no se confirma como payload independiente.

1. Informacion general de la muestra

1.1 Primera caracterizacion

La muestra se identifica como un ejecutable PE32 para Microsoft Windows, arquitectura Intel i386, con subsistema GUI. Los metadatos de version presentan nombres poco coherentes con software legitimo, como Company Name: Sopcast y Original File Name: EquippedRobust.exe. Estos datos no prueban por si solos actividad maliciosa, pero refuerzan la necesidad de tratar el binario como potencialmente ofuscado y manipulado.

Campo	Valor
SHA-256	7e7d0557cc95e3f509f71a72aad9b8ab85d6a681df4a46e1648e928a4be5f4be
MD5	9724934a3ed3a92b38b89fe7a2e9b6fd
Tipo	PE32 executable for MS Windows
Arquitectura	Intel i386 / x86
Subsistema	Windows GUI
Tamaño	311.296 bytes aprox. / 0x4C000
Entry point inicial	0x79C1

1.2 Hashes y footprinting

Los hashes se usan como identificadores estables durante todo el analisis. El SHA-256 coincide con el nombre asignado al archivo en el laboratorio, lo que reduce el riesgo de confusion entre la muestra original, sus copias y los volcados posteriores.

1.3 Consultas externas

Las consultas externas asocian la muestra con Vawtrak/Neverquest. Esta atribucion se usa como hipotesis de apoyo y no como prueba unica. Sirve para priorizar la busqueda de persistencia, configuracion cifrada, comunicacion HTTP/HTTPS, resolucion dinamica de APIs y modulos adicionales.

2. Triage estatico inicial

2.1 Identificacion PE y arquitectura

El triage confirma que el binario es PE32, little endian, no firmado, con simbolos eliminados y sin overlay detectado. La ausencia de overlay reduce la probabilidad de que el payload este simplemente anexo al final del archivo, pero no descarta datos ofuscados dentro de secciones.

Indicador	Resultado	Lectura analitica
Formato	PE32	Ejecutable Windows de 32 bits.
Base	0x400000	Base habitual en PE de Windows.
Firmado	No	Ausencia de firma digital.
Stripped	Si	Sin simbolos utiles para reversing.
Overlay	No	No hay payload anexo de forma trivial al final del archivo.
NX	Si	No impide carga dinamica si el malware usa VirtualAlloc/VirtualProtect.

2.2 Metadatos, imports y strings iniciales

La muestra conserva muchas cadenas directas relacionadas con APIs, runtime, recursos y GUI. No obstante, no aparecen URLs, dominios C2 ni configuracion sensible en claro en la muestra original.

2.3 CAPA sobre la muestra original

CAPA detecta capacidades compatibles con dropper/loader: acceso y escritura de ficheros, extraccion de recursos, parsing de cabeceras PE, resolucion dinamica de APIs, captura de pantalla, descubrimiento de ventanas y terminacion de procesos.

2.4 FLOSS sobre la muestra original

FLOSS recupera cadenas estaticas, pero no stack strings ni decoded strings. La ausencia de cadenas decodificadas no descarta ofuscacion, ya que puede depender de contexto de ejecucion o de rutinas personalizadas.

2.5 Conclusion del triage estatico

El triage no permite recuperar directamente la configuracion ni un payload completo en disco. Por ello, el analisis debe continuar con secciones opacas, funciones de carga y comportamiento dinamico.

3. Validacion de la estructura PE

3.1 Secciones

La muestra presenta secciones convencionales como .text, .rdata, .data, .rsrc y .reloc. La seccion .rdata concentra regiones opacas que inicialmente parecen candidatas a datos comprimidos o cifrados.

3.2 Data Directories

La revision de directorios permite confirmar que la estructura PE es interpretable, aunque algunas regiones de datos requieren validacion manual para evitar falsos positivos al buscar firmas como MZ, PE o PK.

3.3 Firma digital y Rich Header

No se identifica firma digital confiable. La ausencia de firma, junto con metadatos poco coherentes, refuerza la sospecha pero no sustituye el analisis conductual.

4. Analisis de ofuscacion y posible empaquetado

4.1 Comprobacion de UPX/packer

No se confirma un empaquetado UPX convencional. La muestra presenta indicios de ofuscacion y carga dinamica, pero no se desempaqueta mediante una firma de packer trivial.

4.2 Entropia de secciones

La entropia de .rdata permite explicar la alerta heuristica de Detect It Easy. Existen regiones de alta entropia compatibles con datos comprimidos, cifrados u ofuscados.

4.3 Revision de .rdata y blobs opacos

Se extrae .rdata y se buscan firmas MZ, PE, PK, UPX, http, https y TPF0. Aunque aparecen ocurrencias de MZ/PE/PK, la validacion estructural descarta cabeceras validas de PE o ZIP embebido.

4.4 Validacion de falsos positivos MZ/PE/PK

La revision del campo e_lfanew y las firmas posteriores demuestra que las ocurrencias MZ no son cabeceras PE validas. De igual modo, las ocurrencias PK no coinciden con cabeceras ZIP validas.

4.5 Imports sospechosos

Se priorizan APIs como GetProcAddress, LoadLibrary, WriteFile, VirtualAlloc, VirtualFree, CreateFileMapping y MapViewOfFile. Su combinacion es coherente con un loader que resuelve funciones, escribe/copias datos y ejecuta contenido reconstruido en memoria.

4.6 Conclusion sobre empaquetado/ofuscacion

No se recupera un payload embebido de forma directa desde .rdata o .rsrc. La evidencia apunta a reconstruccion dinamica en memoria, por lo que el analisis dinamico se vuelve imprescindible.

5. Analisis funcional estatico de la muestra original

El analisis estatico funcional identifica rutas relacionadas con carga dinamica, parsing PE, escritura de ficheros, resolucion de APIs y gestion de memoria. Sin embargo, la muestra original no expone completamente la logica final. Esta limitacion se explica por la reconstruccion posterior de un payload interno durante la ejecucion.

6. Confirmacion del comportamiento dropper

6.1 Seguimiento de WriteFile/NtWriteFile

En dinamico se observa que la muestra abre su propio fichero, obtiene su tamaño y escribe 0x4C000 bytes, coincidiendo con el tamaño completo de la muestra. Esta secuencia confirma la autocopia.

```
CreateFileA abre la muestra original  
GetFileSize devuelve 0x4C000  
WriteFile/NtWriteFile escribe 0x4C000 bytes  
Resultado: C:\ProgramData\Dizla\Zedyi.exe
```

6.2 Autocopia en C:\ProgramData\Dizla\Zedyi.exe

El fichero Zedyi.exe se crea en ProgramData. Su hash coincide con la muestra original, por lo que se clasifica como autocopia persistente del loader, no como payload final distinto.

6.3 Diferencia entre autocopia y payload final

La autocopia es un artefacto en disco usado para persistencia. El payload final se reconstruye en memoria y se obtiene mediante dump dinamico; contiene la logica posterior, cadenas HTTP/HTTPS y configuracion ofuscada.

7. Analisis dinamico

7.1 Preparacion del entorno de analisis

El analisis dinamico se realiza en una VM Windows controlada con x32dbg, complementando la observacion con Procmon y herramientas de verificacion de hashes. La ejecucion se monitoriza con breakpoints en APIs de fichero, memoria, persistencia, red y terminacion de proceso.

7.2 Autocopia y artefactos en disco

Se confirma la creacion de C:\ProgramData\Dizla\Zedyi.exe. Cuando la VM queda contaminada, el fichero puede reaparecer al eliminarse debido a la persistencia configurada, no por creacion espontanea.

7.3 Comprobaciones de marcadores: Xande, Mizuk y Bupra

Durante la ejecucion se observan comprobaciones de ficheros o marcadores en C:\ProgramData\Dizla, como Xande, Mizuk y Bupra. Estos elementos parecen condicionar rutas de ejecucion o actuar como marcadores de estado. No todos quedan confirmados como ficheros creados por la muestra.

7.4 Persistencia mediante HKCU\...\Run

La persistencia queda confirmada mediante una clave Run en HKCU. El valor Sumos apunta a la autocopia Zedyi.exe, provocando su ejecucion al inicio de sesion del usuario.

```
HKCU\Software\Microsoft\Windows\CurrentVersion\Run\Sumos
"C:\ProgramData\Dizla\Zedyi.exe"
```

7.5 Reserva de memoria y memoria mapeada

Se observa la creacion de objetos de memoria mapeada y regiones privadas con permisos de ejecucion, lectura y escritura. Destaca un mapping anonimo/nombrado de tamaño 0x0010000C y acceso completo, compatible con intercambio de datos o preparacion de estructuras internas.

7.6 Obtencion del payload final reconstruido en memoria

El hallazgo principal del analisis dinamico es la identificacion de una region de memoria que contiene una imagen PE reconstruida. En una ejecucion se documenta la base 0x00110000 y tamaño 0x16000; en otra, un volcado mas amplio desde 0x06CBD5E8 con tamaño 0x1B000. La region se dumpea para su posterior analisis estatico.

7.7 Carga del payload final en Ghidra

El dump mapped_inner_payload_00110000_size_00016000.bin se importa en Ghidra como Raw Binary, x86:LE:32:default:gcc, con base 0x00110000 y longitud 0x16000. Esta configuracion conserva la correspondencia con las direcciones vistas en x32dbg.

7.8 Analisis de funciones relevantes del payload final

La instruccion call eax del loader transfiere la ejecucion a EAX = 0x001166F2. Al cargar el payload con base 0x00110000, esa direccion corresponde al offset 0x66F2 y a la funcion FUN_001166F2 en Ghidra. Por ello se toma como punto de entrada dinamico/dispatcher inicial del payload final.

```
Base del payload: 0x00110000
Entry dinamico: 0x001166F2
Offset interno/RVA: 0x001166F2 - 0x00110000 = 0x66F2
Funcion en Ghidra: FUN_001166F2
```

Funciones priorizadas

```
FUN_001166F2, FUN_0011668C, FUN_00116658, FUN_00112FA2, FUN_001137AC,
FUN_00113AC2, FUN_001138CA, FUN_00113EAF, FUN_00117C26, FUN_00117A6E,
FUN_001177E2, FUN_00113988, FUN_0011853C
```

7.9 Analisis de capacidades del payload final con CAPA/FLOSS

Al analizar el payload final aparecen cadenas y capacidades que no estaban claras en la muestra original: comunicacion HTTP/HTTPS, uso de WinINet, cabeceras HTTP, POST, regsvr32.exe, DllRegisterServer y logica de configuracion.

7.10 Búsqueda de comunicacion C2 y WinINet

El payload final contiene referencias a wininet.dll, http://, https://, POST, Content-Type, Set-Cookie e InternetReadFile/HttpSendRequest o equivalentes. Esto es coherente con comunicacion C2 mediante protocolos web.

7.11 Extraccion y analisis del blob de configuracion

Se localiza un bloque de configuracion con entry_count = 6. El tamaño se calcula como $0x206 + 6 * 0x44 = 0x39E$. Tras dumpearlo y descifrarlo con la rutina correspondiente, se recuperan seis dominios.

```
Base del blob: 0x06B01AE8
Tamaño: 0x39E
Entradas: 6
Algoritmo: LCG + XOR
```

7.12 Analisis del stage/buffer dinamico adicional

Se documentan rutinas adicionales asociadas a buffers dinamicos y resolucion manual de APIs. En esta parte se observan patrones como trampolines, acceso al PEB y resolucion de modulos/funciones por logica propia. Estos hallazgos se mantienen como stage dinamico adicional, separado del payload PE principal.

7.13 Tecnicas anti-analisis y cierre del proceso

El proceso presenta cierres inesperados, sensibilidad al depurador y referencias a IsDebuggerPresent. Tambien se observan rutas que terminan el proceso si no se cumplen ciertas condiciones de entorno o marcadores. Estas tecnicas limitan la observacion completa del comportamiento en x32dbg.

7.14 Limitaciones del analisis dinamico

No se confirma la ejecucion efectiva de algunas capacidades potenciales, como regsvr32.exe o descarga de payload adicional. Tampoco se confirma inyeccion en proceso remoto. Por ello, la entrega diferencia entre hallazgos confirmados, probables y potenciales.

8. Indicadores de compromiso

Los indicadores se dividen entre IOCs confirmados y artefactos relevantes de analisis. Esta separacion evita sobreafirmar elementos que se observaron como referencias o candidatos, pero que no quedaron confirmados como objetos creados o ejecutados.

8.1 IOCs confirmados

Categoria	Indicador	Valor	Descripcion
Hash	SHA-256	7e7d0557cc95e3f509f71a72aad9b8ab85d6a681df4a46e1648e928a4be5f4be	Hash principal de la muestra original.
Hash	MD5	9724934a3ed3a92b38b89fe7a2e9b6fd	Hash MD5 de la muestra original.
Fichero	Autocopia	C:\ProgramData\Dizla\Zedyi.exe	Mismo hash que la muestra original; autocopia persistente.
Registro	Run key	HKCU\Software\Microsoft\Windows\CurrentVersion\Run\Sumos	Persistencia en inicio de sesion del usuario.
Registro	Valor Run	"C:\ProgramData\Dizla\Zedyi.exe"	Ruta ejecutada por la clave Run.
Dominio C2	Dominio	ninthclub.com	Dominio recuperado de configuracion.
Dominio C2	Dominio	camelcap.com	Dominio recuperado de configuracion.
Dominio C2	Dominio	ideagreens.com	Dominio recuperado de configuracion.
Dominio C2	Dominio	guesstrade.com	Dominio recuperado de configuracion.
Dominio C2	Dominio	castuning.ru	Dominio recuperado de configuracion.
Dominio C2	Dominio	mgsmmedia.ru	Dominio recuperado de configuracion.

8.2 Artefactos relevantes de analisis

Categoria	Artefacto	Valor	Estado / uso
Payload	Dump principal	mapped_inner_payload_00110000_size_00016000.bin	Payload PE reconstruido en memoria; entry dinamico 0x001166F2.
Payload	Dump alternativo	payload_final_06CBD5E8_1B000.bin	Volcado mas amplio desde otra ejecucion/base.
Config	Blob	config_blob.bin	Bloque de configuracion dumper desde memoria.
Config	Base	0x06B01AE8	Inicio del bloque de configuracion.
Config	Tamaño	0x39E	Calculado a partir de seis entradas.
Marcador	Xande	C:\ProgramData\Dizla\Xande	Comprobacion de existencia; no confirmada como creacion.
Marcador	Mizuk	C:\ProgramData\Dizla\Mizuk	Referencia observada durante ejecucion.
Marcador	Bupra	C:\ProgramData\Dizla\Bupra	Referencia observada durante ejecucion.
Tarea	ProgramDataUpdater	\MicrosoftWindowsApplicationExperienceProgramDataUpdater	Sospechosa; pendiente si apunta al malware.
Red	HTTP strings	POST, http://, https://, Content-Type, Set-Cookie	Evidencia de comunicacion web en payload final.
LOLBIN	regsvr32	regsvr32.exe /s /i:"%" "%s"	Capacidad potencial; no confirmada como ejecucion.
Blob	Base64	EA10Ep69...W4Wwq	Decodifica a 249 bytes de alta entropia; no payload confirmado.

9. Mapeo MITRE ATT&CK

El mapeo MITRE se clasifica por nivel de confianza. Se consideran confirmadas las tecnicas con evidencia directa en el analisis. Las probables o potenciales se incluyen para orientar la defensa, pero no deben tratarse como comportamiento demostrado al mismo nivel.

9.1 Tecnicas confirmadas

ID	Tecnica	Evidencia	Estado
T1547.001	Registry Run Keys / Startup Folder	HKCU\...\Run\Sumos apunta a C:\ProgramData\Dizla\Zedyi.exe.	Confirmada
T1112	Modify Registry	Creacion/modificacion de la clave de persistencia Run.	Confirmada
T1083	File and Directory Discovery	Uso de rutas en ProgramData y comprobacion de ficheros/marcadores.	Confirmada
T1106	Native API	Uso de NtWriteFile, NtCreateSection/NtMapViewOfSection o equivalentes en ntdll.	Confirmada
T1129	Shared Modules	LoadLibrary/GetProcAddress y carga dinamica de wininet.dll.	Confirmada
T1027	Obfuscated Files or Information	Regiones de alta entropia, blobs y configuracion ofuscada.	Confirmada
T1140	Deobfuscate/Decode Files or Information	Reconstruccion del payload y descifrado de configuracion LCG + XOR.	Confirmada
T1071.001	Web Protocols	HTTP/HTTPS, POST, WinINet y cabeceras HTTP.	Confirmada
T1113	Screen Capture	CAPA detecta GetDC, BitBlt, CreateCompatibleDC/Bitmap.	Confirmada por CAPA
T1010	Application Window Discovery	FindWindow y GetWindowText detectados por CAPA.	Confirmada por CAPA
T1082	System Information Discovery	GetSystemInfo y variables de entorno.	Confirmada por CAPA

9.2 Tecnicas probables o potenciales

ID	Tecnica	Evidencia	Estado
T1620	Reflective Code Loading	Payload PE reconstruido en memoria y transferencia por call eax a 0x001166F2.	Probable
T1573	Encrypted Channel	Uso de HTTPS y datos ofuscados/cifrados.	Probable
T1497.003	Time Based Evasion	Sleep o retrasos detectados por CAPA.	Probable
T1622	Debugger Evasion	IsDebuggerPresent, cierres e inestabilidad bajo depuracion.	Probable
T1480	Execution Guardrails	Marcadores Xande, Mizuk, Bupra como condiciones de flujo.	Probable
T1036	Masquerading	Metadatos Sopcast/EquippedRobust y ruta/nombres que aparentan legitimidad.	Probable
T1218.010	Regsvr32	Cadena regsvr32.exe /s /i y DllRegisterServer.	Potencial
T1105	Ingress Tool Transfer	Capacidad de recibir/procesar datos HTTP; no descarga confirmada.	Potencial
T1053.005	Scheduled Task	Tarea sospechosa ProgramDataUpdater; no confirmada como apuntando al malware.	Pendiente
T1055	Process Injection	Memoria ejecutable y payload en memoria; no se observa proceso remoto.	No confirmada

10. Conclusiones finales

El analisis realizado permite concluir que la muestra corresponde a un ejecutable PE32 de Windows con comportamiento malicioso compatible con un loader/dropper asociado a Vawtrak/Neverquest. La asociacion con la familia se usa como apoyo OSINT y se complementa con evidencias propias obtenidas durante el analisis estatico y dinamico.

En la fase estatica se caracterizo la muestra como un binario de 32 bits, sin firma digital, con metadatos incoherentes e indicios de ofuscacion parcial. Aunque conserva numerosas cadenas visibles relacionadas con APIs, runtime y recursos, no expone directamente dominios, URLs C2 ni configuracion en claro. La revision de .rdata mostro regiones de alta entropia compatibles con datos cifrados o comprimidos, pero la validacion manual descarto la existencia de un PE, ZIP o UPX directamente recuperable desde esa seccion.

El analisis dinamico confirmo que la muestra realiza una autocopia en C:\ProgramData\Dizla\Zedyi.exe. La comparacion de hashes demuestra que Zedyi.exe coincide con la muestra original, por lo que se clasifica como autocopia persistente del loader, no como payload nuevo. La persistencia queda confirmada mediante la clave HKCU\Software\Microsoft\Windows\CurrentVersion\Run\Sumos, que apunta a dicha autocopia.

Ademas de la autocopia, se observo el uso de memoria mapeada y regiones privadas con permisos ejecutables. El hallazgo mas relevante fue la obtencion de un payload final reconstruido en memoria. En x32dbg se observo que el loader transfiere ejecucion mediante call eax a 0x001166F2. Al cargar el dump en Ghidra con base 0x00110000, esa direccion corresponde al offset 0x66F2 y a FUN_001166F2, identificada como punto de entrada dinamico o dispatcher inicial del payload final.

El payload final contiene cadenas y logica asociadas a comunicacion HTTP/HTTPS, uso de WinINet, metodo POST, cabeceras HTTP y procesamiento de respuestas. Tambien se identifican referencias a regsvr32.exe y DllRegisterServer, aunque su ejecucion efectiva no quedo confirmada durante las pruebas. Por ello, se clasifica como capacidad potencial y no como comportamiento demostrado.

Otro resultado clave es la recuperacion de un bloque de configuracion cifrado/ofuscado. Tras identificar seis entradas y aplicar la logica de descifrado basada en LCG + XOR, se recuperaron los dominios ninthclub.com, camelcap.com, ideagreens.com, guesstrade.com, castuning.ru y mgsmedia.ru. Estos dominios constituyen los indicadores de red mas relevantes del analisis.

Tambien se identifico un blob Base64 largo dentro del payload final, que decodifica a 249 bytes binarios de alta entropia. Sin embargo, al no presentar cabeceras conocidas, cadenas legibles ni estructura PE, no se considera payload adicional confirmado. Se documenta como candidato a datos cifrados, comprimidos u ofuscados.

Durante el analisis se observaron limitaciones relevantes: cierres inesperados del proceso, sensibilidad al depurador, referencias a IsDebuggerPresent y rutas condicionadas por marcadores como Xande, Mizuk o Bupra. Estos elementos apuntan a tecnicas anti-analisis o guardrails de ejecucion, aunque no todas pudieron confirmarse con el mismo nivel de certeza.

Cadena de comportamiento confirmada

- La muestra original actua como loader/dropper.
- Se autocopia como C:\ProgramData\Dizla\Zedyi.exe.
- Establece persistencia mediante HKCU\...\Run\Sumos.
- Usa memoria mapeada y regiones privadas ejecutables.
- Reconstruye un payload PE en memoria.
- Transfiere ejecucion al payload mediante call eax hacia 0x001166F2.
- El payload contiene logica HTTP/HTTPS y configuracion C2 ofuscada.
- Se recuperan seis dominios asociados a esa configuracion.
- Se observan indicios de anti-analisis que dificultan la ejecucion completa.

Desde el punto de vista MITRE ATT&CK, los comportamientos confirmados se relacionan principalmente con persistencia mediante claves Run, modificacion del registro, uso de APIs nativas, carga dinamica de modulos, ofuscacion/decodificacion de informacion, comunicacion por protocolos web, descubrimiento del sistema, interaccion con ventanas y captura de pantalla. Otros comportamientos, como regsvr32, descarga de componentes adicionales, tareas programadas o inyeccion en procesos, quedan como potenciales o pendientes de confirmacion.

Conclusion global: la muestra presenta una arquitectura por fases: loader inicial, autocopia persistente y payload final reconstruido en memoria. La combinacion de ofuscacion, reconstruccion dinamica, persistencia, configuracion cifrada y comunicacion HTTP/HTTPS es coherente con un malware bancario modular. El analisis permitio extraer indicadores relevantes, confirmar la persistencia, recuperar dominios de configuracion y documentar el mecanismo de transicion hacia el payload final, aunque la ejecucion completa quedo parcialmente limitada por comportamientos anti-analisis.